

Engineering Evidence Report

Version 0.2.0 | Status date 2026-08-18

This report records implemented software controls, executed engineering tests, actual reference-container measurements, scientific figures, and the release gates that still require real participants, named providers, target hardware, or independent reviewers.

Evidence boundary

The SDK is a research and integration component. It is not a clinically validated model, medical-device clearance, diagnostic or treatment recommendation, HIPAA certification, accessibility conformance claim, or substitute for independent clinical, regulatory, security, and statistical review.

1. Executive conclusion

The repository now contains enforceable implementations for the requested engineering controls: an explicit disengagement endpoint, held-out evaluation tooling, participant-level confidence intervals, subgroup and drift analysis, immutable provider-manifest enforcement, host authentication/authorization, encrypted storage, versioned consent, retention and deletion, incident logging, and signed model/config packages. Ten editable scientific and hardware SVG figures and reproducible test protocols are included.

The software can execute the required analyses, but no real held-out participant dataset, named provider approval, target-device energy result, penetration test, or independent clinical/regulatory opinion was provided. Those items are correctly marked open rather than replaced with synthetic claims.

Area	Repository result	Evidence status
Outcome	120-second versioned composite event with censoring	Implemented and tested
Validation	Calibration, specificity, false interventions/hour, AUROC, AUPRC, cluster-bootstrap CI	Tooling tested; participant run pending
Action safety	Deep-frozen reviewed manifest, contraindications, no_action	Enforcement tested; provider approval pending
Security/privacy	Auth adapter, AES-GCM, consent, TTL, deletion, incidents, Ed25519	Software tested; deployment controls pending
Threat/accessibility	Internal threat model and static WCAG smoke suite	Internal/static complete; independent/manual pending
Device evidence	Latency, memory, CPU and external-energy harness	Container run complete; named endpoints pending
Clinical/regulatory	Internal issue-spotting packet and signature form	Independent review pending

2. Locked disengagement endpoint

At decision time t_0 , the model predicts whether a qualifying disengagement occurs during $(t_0, t_0 + 120 \text{ seconds}]$. The endpoint version is disengagement-v1.0.0. A positive event can be premature task exit, omission followed by 30 seconds of inactivity, 30 seconds of inactivity while an active task expects interaction, or failure to resume within 30 seconds after a scheduled break or acknowledged prompt.

- Label 1: a qualifying composite event is observed inside the horizon after protocol exclusions.
- Label 0: the complete horizon is observed with no qualifying event.
- Censored: follow-up ends before the horizon without a positive event.
- An observed positive remains positive even if later follow-up is lost.
- Raw interaction gaps are not endpoints until the event-generation pipeline applies context and exclusions.

Primary source: `sdk/docs/VALIDATION_PROTOCOL.md`. Executable source: `sdk/src/outcomes.js`.

3. Held-out validation and statistical tests

The command `scripts/validate-model.mjs` requires every row to identify a participant and use `split=held_out`. The analysis excludes censored rows from binary point estimates while retaining their count in study accounting. Whole participants, not rows, are resampled for confidence intervals.

Metric	Definition / repository output
Calibration	Reliability bins, expected calibration error, and Brier score
Specificity	$TN / (TN + FP)$ at the locked threshold
False interventions/hour	False-positive decisions / non-overlapping monitored hours
AUROC	Tie-aware rank statistic across positive and negative labels
AUPRC	Average precision across descending predicted risk
Confidence intervals	Percentile interval from participant-cluster bootstrap
Subgroups	Same locked metrics by prespecified field; small-cell policy required
Drift	Population stability index plus standardized mean shift

Required execution: `npm run validate:model -- --input held-out.jsonl --output evidence/model-validation.json --threshold [locked value] --subgroup [field] --iterations 5000`

4. Provider action library and contraindications

FrozenActionManifest refuses a manifest unless status is approved and provider review metadata is complete. It validates action definitions and contraindication references, prevents rules from denying no_action, deep-freezes the approved content, and prevents runtime action registration. The draft file config/action-manifest.pending.json is intentionally marked pending_provider_review and cannot be loaded as approved.

- Review exact wording, population, setting, timing, burden, repeat limit, plausible harms, and escalation.
- Mark exploration unsafe by default and require explicit provider approval for protected actions.
- Express each stop condition as a machine-readable deny rule with clinical rationale.
- Re-review and re-sign every change to action wording, thresholds, contraindications, model, or configuration.

5. Security, privacy, and governance controls

Control	Implementation	Deployment responsibility
Identity	HostAuthorizer verifies a host principal and permission	OIDC/FIDO/session lifecycle and least privilege
Encryption	AES-256-GCM, random IV, storage-key AAD, key ID	Keystore/HSM, rotation, backup and recovery
Consent	Version, purposes, grant, expiry, revoke, persist, delete	Approved text, UX, re-consent and reconciliation
Retention	Decision TTL and persisted-state expiry	Approved schedule, backup and legal-hold handling
Deletion	Subject decisions, current state, and consent removed	External sinks, exports, upstream stores, backups
Incidents	Structured severity/category/component log and sink	Monitoring, escalation, response and reporting
Integrity	Canonical Ed25519 sign/verify and trusted-version hook	Offline keys, public-key pinning, revocation, anti-rollback

6. Threat-model findings

An internal data-flow and STRIDE-style review was completed on 2026-08-18. Highest-severity scenarios are modified runtime packages, contraindicated actions, and compromised endpoints/action executors. Repository mitigations reduce risk but do not replace host hardening or independent penetration testing.

Threat	Initial	Primary control	Open work
Forged identity	High	Host verification + permissions	Identity integration tests
State disclosure/swap	High	AES-GCM + AAD	Key lifecycle + backup tests
Model/config tamper	Critical	Ed25519 + verified factory	Offline custody + anti-rollback
Unsafe action	Critical	Manifest + contraindications + no_action	Provider hazard review
Raw leakage	High	Immediate consume; no sample-window export	Inspect host logs/crash/network tools
Endpoint/executor compromise	Critical	Allowlisted action ID	Code signing, sandbox, device hardening

7. Accessibility testing

The executed static smoke suite passed 10 of 10 checks for the browser example: language, viewport, main landmark, heading, button type and accessible name, visible focus, 44-pixel targets, live status, and reduced-motion handling. This is not a WCAG conformance claim. Manual WCAG 2.2 AA and assistive-technology testing of the complete host product remains open.

8. Actual reference-container measurements

Measure	Actual recorded value
Host	AMD EPYC 9V74 80-Core Processor; linux x64; Node v24.19.0
Workload	5000 ingests and 500 decisions after 500 warm-up samples
Ingest latency	mean 0.01107 ms; p95 0.02752 ms; p99 0.04153 ms; max 1.45386 ms
Decision latency	mean 0.10223 ms; p95 0.22914 ms; p99 0.48470 ms; max 1.27224 ms
Observed peak heap	16,588,848 bytes
CPU	26.118 microseconds per measured operation
Energy	Not measured; external device power input is required
Raw records after run	0

These are actual engineering measurements on an unidentified CI/container host. They are not target-device, battery, clinical, or scalability evidence.

9. Test results

Executed on 2026-08-18 with Node v24.19.0: 27 unit tests passed, 0 failed. The accessibility smoke suite passed 10 of 10 checks. JavaScript syntax checks passed for source, scripts, and benchmarks; repository JSON parsed successfully. The benchmark retained zero raw-buffer records after execution.

- Outcome positives, negatives, and early censoring.
- Known-value AUROC, AUPRC, specificity, burden rate, calibration, bootstrap CI, subgroup and drift behavior.
- Frozen manifest immutability, contraindication masking, and no runtime extension.
- AES-GCM ciphertext round-trip without plaintext marker in the inner adapter.
- Ed25519 verification, tamper rejection, trusted runtime loading, and encrypted-storage production gate.
- Authentication, active consent, retention, deletion, incident records, approval, and reward censoring.

10. Clinical and regulatory screening

This report does not make a regulatory determination. Patient-facing software that analyzes interaction or sensor-derived signals and changes a therapeutic experience should not be assumed to be non-device clinical decision support. Classification depends on the final intended use, claims, users, inputs, action effects, population, and jurisdiction. HIPAA applicability depends on the entities and data flows; software components alone do not establish compliance.

Independent clinical and regulatory reviewers must document qualifications and conflicts, reviewed versions, intended-use and classification conclusions, evidence sufficiency, subgroup and action risks, required controls, and signed release conditions. The signature form is in `sdk/docs/CLINICAL_REGULATORY_REVIEW_PACKET.md`.

11. Open release gates

- Collect a participant-disjoint silent-mode held-out dataset under the approved endpoint and protocol; run and independently review all locked metrics and confidence intervals.
- Obtain named provider approval for the exact action library and contraindications; sign the approved runtime package.
- Integrate the real identity provider, keystore/HSM, monitored audit/incident sinks, backup/deletion workflow, and version rollback policy.
- Run independent security review and penetration testing, manual accessibility/assistive-technology testing, and all named device/OS latency, memory, CPU, thermal, and external energy tests.
- Complete qualified independent clinical and regulatory assessments and approve numerical release thresholds, monitoring, stopping, and escalation rules.

12. Repository deliverables

Path	Purpose
sdk/src	SDK engine, outcome, validation, manifest, security, consent, persistence and policy modules
sdk/test/sdk.test.js	27-test engineering verification suite
sdk/scripts	Validation, signing, verification, accessibility, syntax and report tools
sdk/benchmarks	Reference and named-device performance harnesses
sdk/config	Deliberately pending provider/runtime templates
sdk/schemas	Telemetry, action, manifest and held-out row schemas
sdk/docs	Protocols, threat model, review packets and figure index
sdk/evidence	Machine-generated results with limitations
output/pdf	This consolidated evidence report

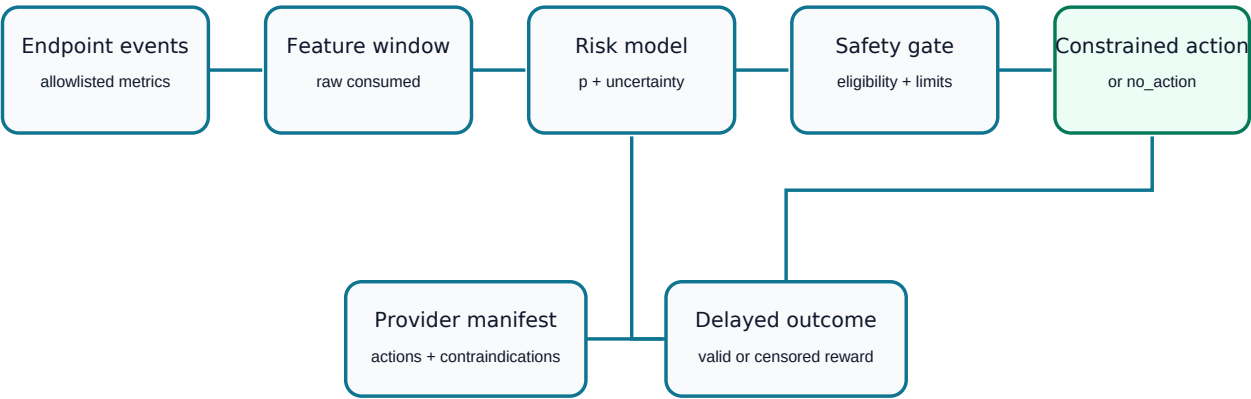
13. Primary public references

- FDA, Clinical Decision Support Software guidance (January 2026):
<https://www.fda.gov/regulatory-information/search-fda-guidance-documents/clinical-decision-support-software>
- FDA, Policy for Device Software Functions and Mobile Medical Applications: <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/policy-device-software-functions-and-mobile-medical-applications>
- FDA, Cybersecurity in Medical Devices guidance: <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/cybersecurity-medical-devices-quality-management-system-considerations-and-content-premarket>
- HHS, Summary of the HIPAA Security Rule:
<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>
- W3C, Web Content Accessibility Guidelines 2.2: <https://www.w3.org/TR/WCAG22/>

Appendix A. Scientific and hardware figures

The following editable SVGs are maintained in `sdk/docs/figures`. Figure 8 is intentionally a blank calibration template; it must not be populated without locked held-out data.

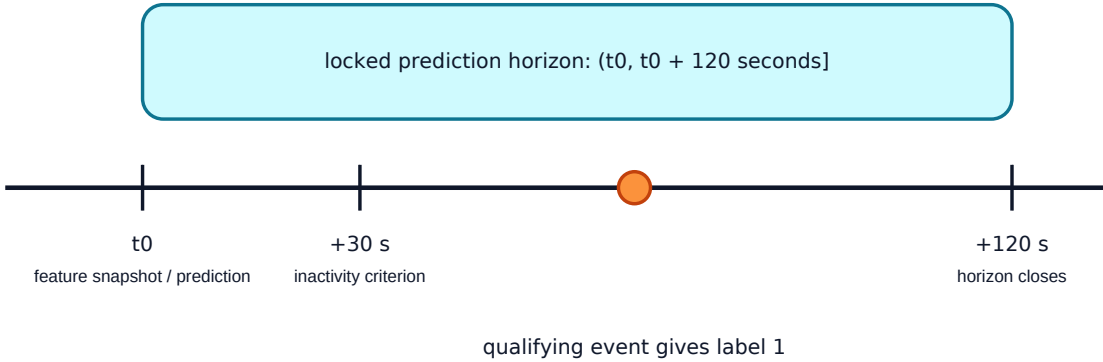
Figure 1. System architecture



Invariant: action selection can only choose from the reviewed, non-contraindicated set; no_action is always available.

01 System Architecture

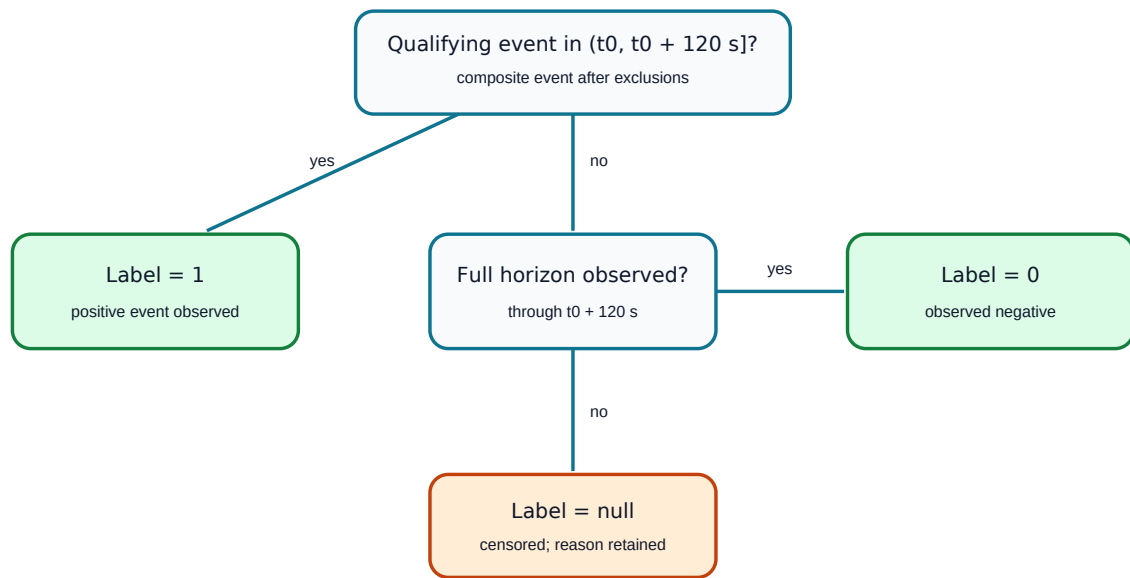
Figure 2. Prediction window and endpoint timing



No event + full follow-up gives 0. No event + early observation loss is censored. Observed positive events remain positive.

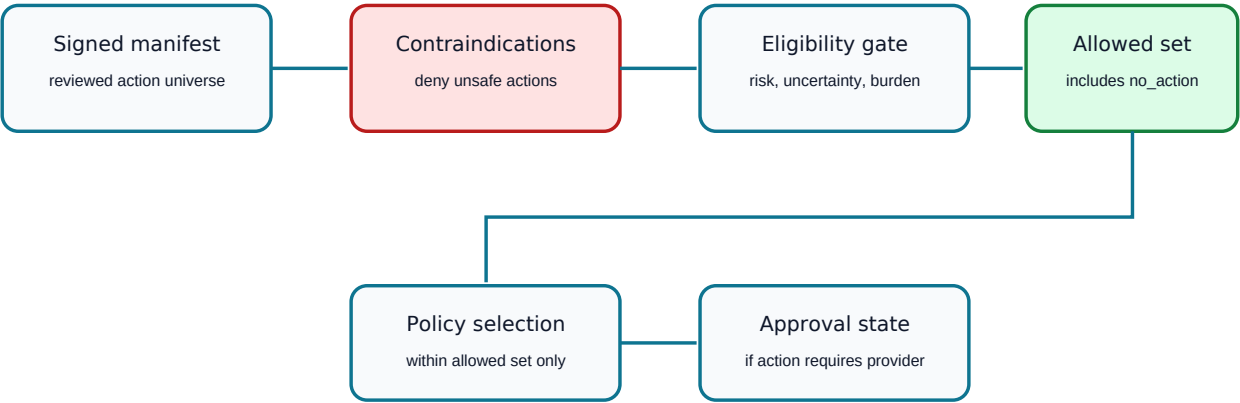
02 Prediction Window

Figure 3. Endpoint labeling and censoring



03 Outcome Labeling

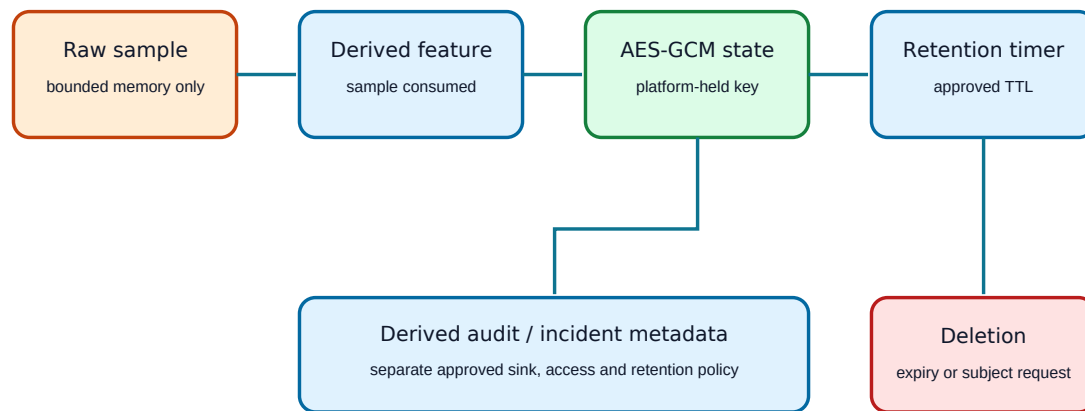
Figure 4. Provider-constrained action gating



Fail-safe behavior: disabled protocol, failed gate, empty allowed set, or cooldown gives no_action.

04 Action Gating

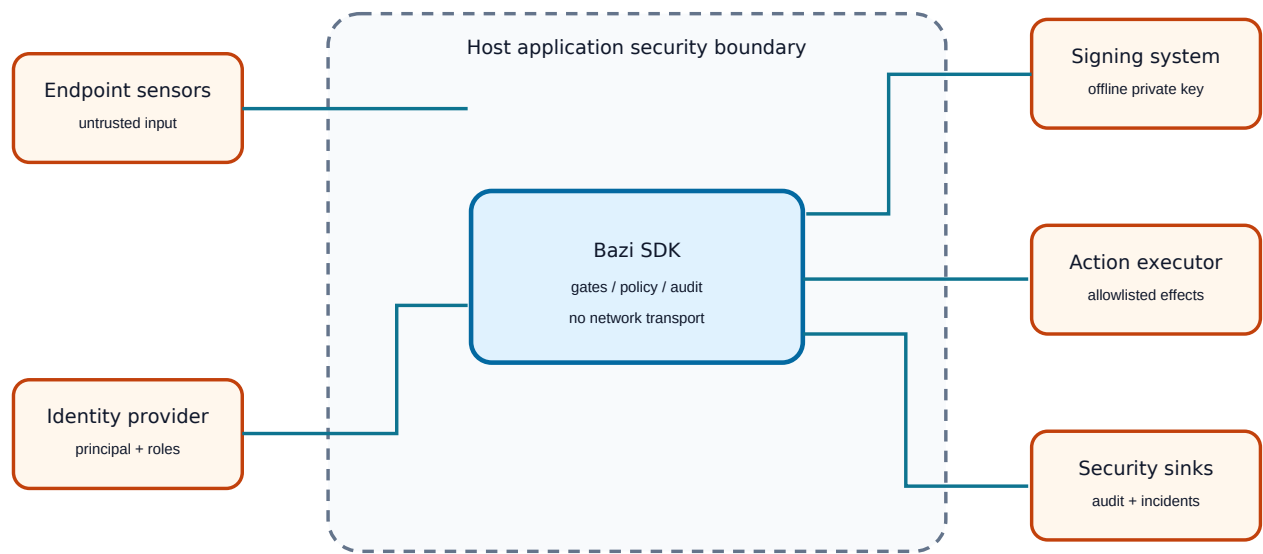
Figure 5. Data lifecycle and deletion



Deletion verification must include host databases, external sinks, backups, exports, and legal holds - not only the SDK adapter.

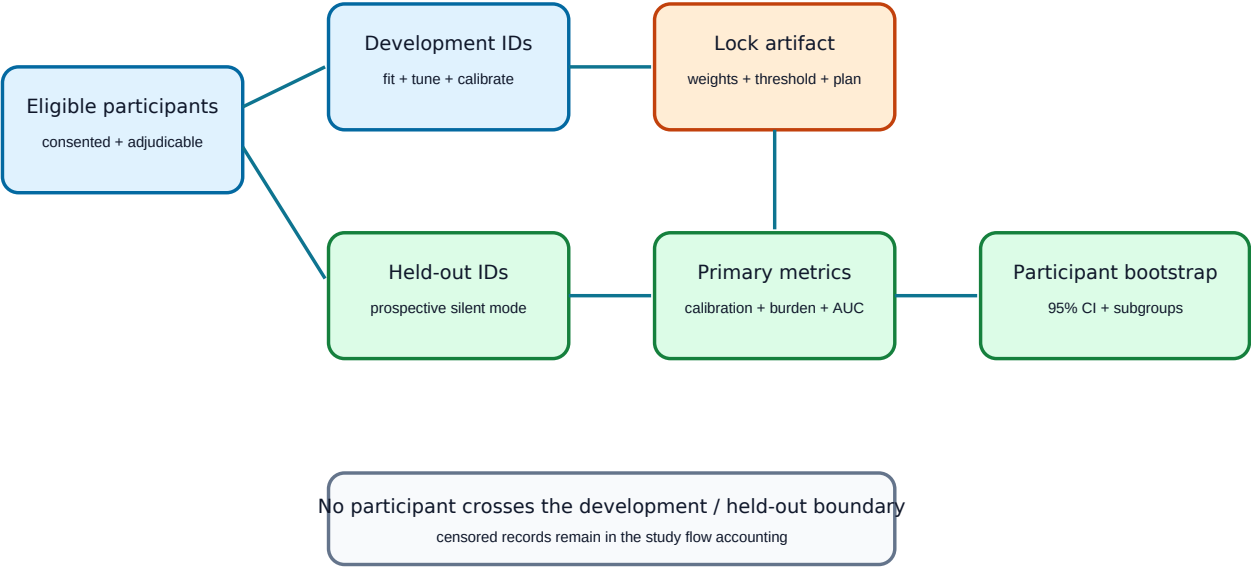
05 Data Lifecycle

Figure 6. Security trust boundaries



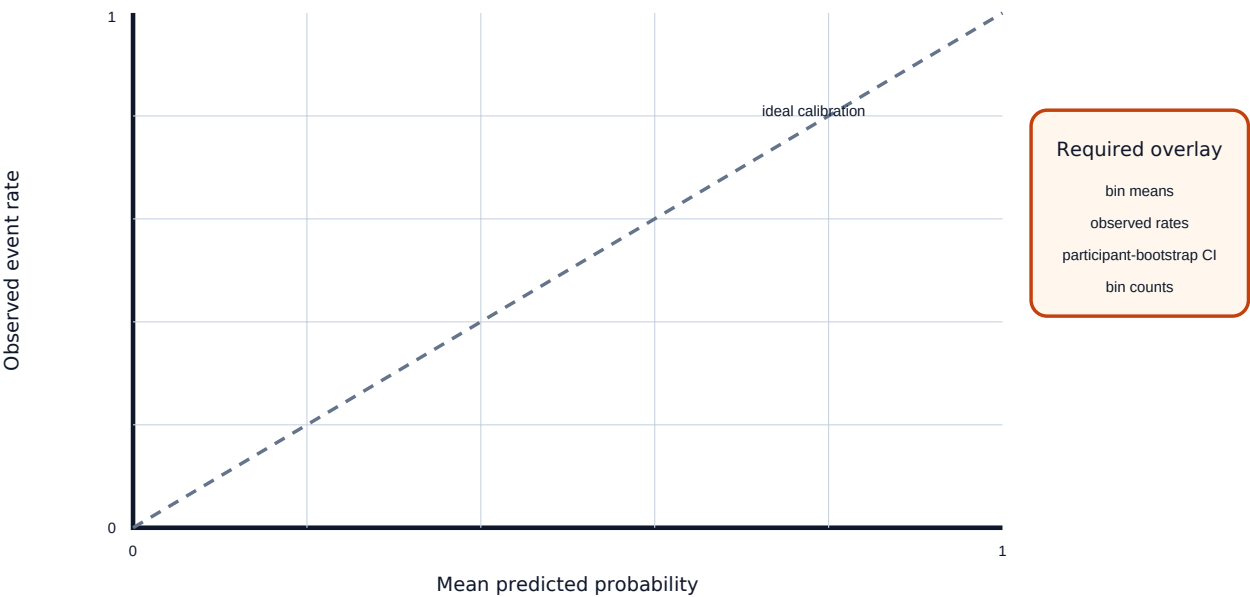
06 Trust Boundaries

Figure 7. Participant-disjoint held-out validation



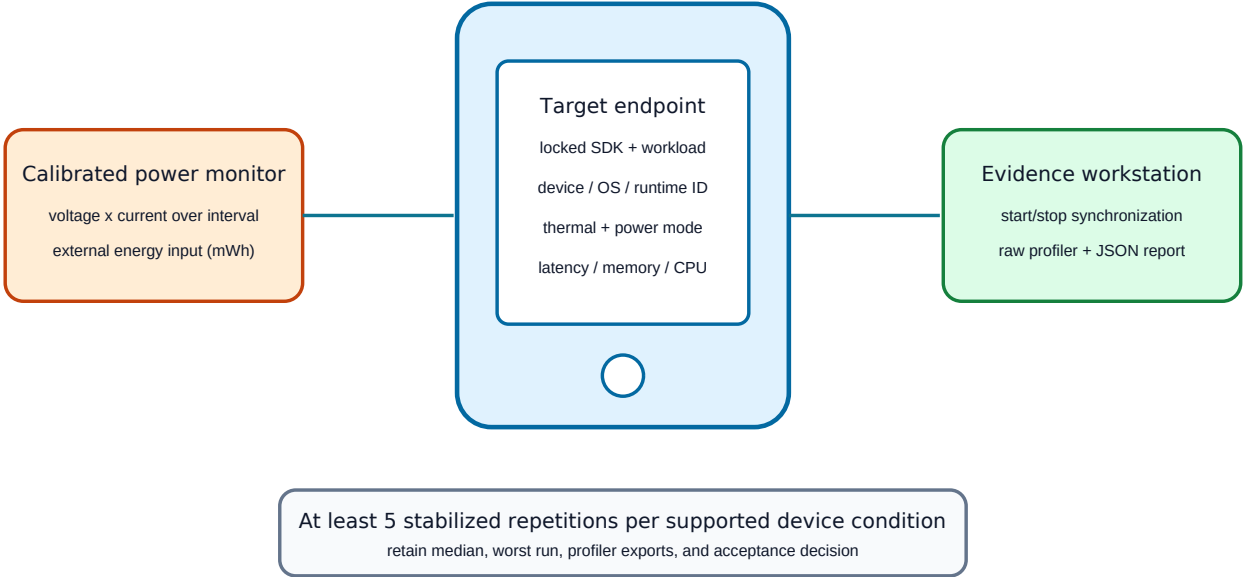
07 Validation Study

Figure 8. Calibration plot template - no participant data



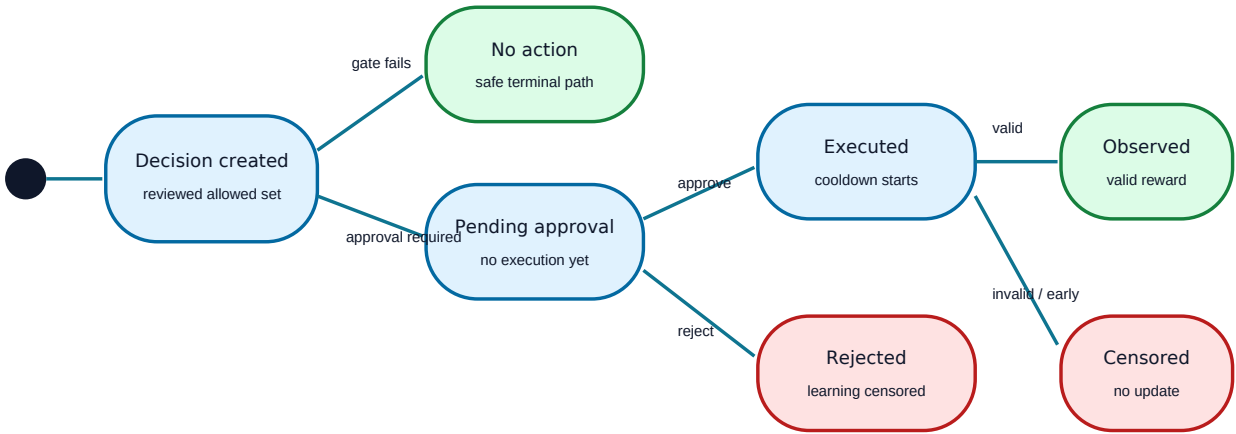
08 Calibration Template

Figure 9. Device latency, memory, and energy test setup



09 Hardware Test Setup

Figure 10. Intervention safety state machine



Only valid, complete, unconfounded outcomes from executed non-no_action decisions update the local policy.

10 Safety State Machine